

Reporte de Vulnerabilidades de Seguridad

Proyecto: DockerFlaskDesplegado

Fecha: 25 de Agosto de 2026

1. Tabla de Reporte de Vulnerabilidades

Herramienta	Nombre del Fallo	Severidad	Solucion
Bandit (SAST)	Hardcoded Password	HIGH	Usar variable de entorno os.getenv()
Bandit (SAST)	Debug Mode Enabled	MEDIUM	Remover debug=True del codigo
Trivy (Imagen)	Vulnerable Base Image	CRITICAL	Actualizar a python:3.12-slim
Pytest (Prueba)	Test Failure Status 500	HIGH	Restaurar assert status_code == 200

2. Explicacion de las Soluciones

Fallo SAST (Bandit) - Clave Hardcodeada:

Se removio la variable MYSQL_PASSWORD = 'super_secret_123' del codigo. Se reemplazo por os.getenv('password') para leer la contraseña desde variables de entorno, manteniendo las credenciales fuera del repositorio.

Fallo SAST (Bandit) - Debug Mode:

Se removio el parametro debug=True de sample.run(). El modo de depuracion en produccion puede exponer informacion sensible y rastros de errores.

Fallo Imagen (Trivy):

Se cambio la imagen base de python:3.8-slim-buster a python:3.12-slim. La imagen anterior contenia multiples vulnerabilidades conocidas (CVEs) en el sistema operativo y librerias del sistema.

Fallo Prueba (Pytest):

Se restauro el assert de status_code == 500 a status_code == 200. La ruta / debe devolver exitosamente la pagina de estado de la base de datos.

3. Evidencias del Pipeline

Reporte de Vulnerabilidades de Seguridad

Captura 1: Pipeline Fallido (ROJO)

El pipeline de GitHub Actions falla en la etapa de testing/seguridad. Bandit detecta la clave hardcodeada y pytest falla porque la ruta / devuelve 500 en lugar de 200. El despliegue automatico se cancela.

Captura 2: Pipeline Exitoso (VERDE)

Despues de aplicar los parches de seguridad, el pipeline pasa todas las verificaciones: Bandit no detecta vulnerabilidades, pytest pasa exitosamente, Trivy no encuentra vulnerabilidades criticas en la imagen. El despliegue se ejecuta correctamente.

Captura 3: Verificacion Final de la API

La aplicacion Flask esta funcionando correctamente en el dominio HTTPS de DuckDNS. La ruta / muestra el estado de conexion a la base de datos y la API responde con status 200 OK.